Lab 30 — Asset Inventory, Media Sanitisation and Disposal Certificate

> **SY0-701 Objective 4.2** — Explain the security implications of proper hardware, software, and data asset management.
>
> **Domain 4** — Security Operations (28%) · **Time:** ~10 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: Track an asset from inventory to disposal: record its owner and classification, enumerate what the host really has, check retention and legal hold, prove that deleting is not sanitising, wipe a block device with `shred`, `dd` and `blkdiscard`, verify every byte, perform a cryptographic erase, and issue a NIST SP 800-88 certificate of sanitisation.

You'll build: `/root/itam/` containing an asset inventory, a host enumeration record, a retention schedule, read-back verification evidence and a signed-off certificate of sanitisation, with the inventory status updated.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; Lab 23 (data classification) and Lab 24 (LUKS) are helpful background; tools installed in step 1.

Background

- **Asset management** covers the whole lifecycle: **acquisition/procurement** (buy from approved sources with security requirements), **assignment/accounting** (an owner, a custodian and a classification for every asset), **monitoring/asset tracking** (inventory plus enumeration to find what is really out there) and **disposal/decommissioning**.
- **Inventory** is the record of what you believe you own. **Enumeration** is active discovery of what is actually present. The gap between them is unmanaged risk such as shadow IT, lost devices and unpatched software.
- **NIST SP 800-88** defines three sanitisation levels. **Clear** means logical overwrite, which defeats software recovery. **Purge** defeats laboratory recovery through cryptographic erase, block erase or degaussing. **Destroy** means shredding, disintegrating, pulverising or incinerating the media.
- **Certification** is the documented proof (a certificate of sanitisation or destruction) that the media was processed and verified. It is often supplied by a third-party disposal vendor.
- **Data retention** rules (legal, regulatory and contractual) decide when data may be destroyed. A **legal hold** overrides normal disposal.

Steps

1. Install the tools

Most of these are present already; installing them makes the lab repeatable.

```
apt-get update -qq && DEBIAN_FRONTEND=noninteractive apt-get install -y util-linux
coreutils e2fsprogs cryptsetup jq bsdextrautils || apt-get install -y util-linux coreutils
```

```
e2fsprogs cryptsetup jq
mkdir -p /root/itam
```

2. Build the asset inventory and enumerate this host

The inventory records **ownership** (the accountable business owner), the **custodian** (who looks after it day to day) and the **classification**. Enumeration then collects what this machine actually is and runs, which is the data an agent or a discovery scan feeds into a CMDB.

```
cd /root/itam
cat > inventory.csv <<'EOF'
asset_tag,type,model,serial,owner,custodian,classification,location,status
SG-LT-0142,laptop,Latitude 7440,SN-7F3K92,Finance (CFO),IT Ops,Confidential,SG-HQ,In
service
SG-SRV-0007,server,PowerEdge R650,SN-Q2LX81,Payments (Head of Payments),Infra
Team,Restricted,SG-DC1,In service
SG-USB-0031,usb-drive,Kingston DT 32GB,SN-KDT331,HR (HR Director),IT Ops,Confidential,SG-
HQ,Lost - reported
SG-DISK-0099,disk,Virtual 64MiB,SN-LAB0099,Finance (CFO),IT Ops,Confidential,Lab,Retired
EOF
column -s, -t < inventory.csv
jq -n --arg host "$(hostname)" --arg os "$(. /etc/os-release; echo "$PRETTY_NAME")" --arg
kernel "$(uname -r)" \
  --argjson pkgs "$(dpkg-query -W | wc -l)" --argjson disks "$(lsblk -J -d -o
NAME,SIZE,TYPE)" \
  '{host:$host, os:$os, kernel:$kernel, installed_packages:$pkgs,
disks:$disks.blockdevices}' | tee host-enum.json
dpkg-query -W -f='${Package} ${Version}\n' > software-inventory.txt
grep -E '^(telnet|john|hydra|nmap) ' software-inventory.txt || echo "No unapproved tools
found in the software inventory"
```

3. Check retention and legal hold before disposal

Before any media is wiped, the data owner confirms that the retention period is satisfied and that no legal hold applies. Recording that decision is part of the audit trail.

```
cd /root/itam
cat > retention-schedule.csv <<'EOF'
record_type,retention_period,basis,legal_hold
customer_invoices,5 years after the financial year,tax and accounting law,no
payroll_records,7 years,employment records policy,no
cctv_footage,30 days,privacy policy (PDPA),no
incident_2026_017_evidence,until the case is closed,legal counsel instruction,yes
EOF
cat > disposal-request-SG-DISK-0099.txt <<'EOF'
asset_tag=SG-DISK-0099
contents=customer_invoices (working copies; system of record is the ERP)
retention_met=yes
legal_hold=no
approved_by=Finance data owner
EOF
grep -q '^legal_hold=no' disposal-request-SG-DISK-0099.txt && grep -q '^retention_met=yes'
disposal-request-SG-DISK-0099.txt \
  && echo "RETENTION CHECK PASSED - disposal of SG-DISK-0099 approved"
```

4. Prove that deleting is not sanitising

Attach a 64 MiB image as a loop block device (asset SG-DISK-0099), put a file system on it, write synthetic confidential records, delete the file and unmount. The raw device still contains the data.

```
cd /root/itam
truncate -s 64M retired-disk.img
LOOP=$(losetup -f --show retired-disk.img); echo "$LOOP" > loopdev; echo "SG-DISK-0099
attached as $LOOP"
mkfs.ext4 -q "$LOOP"
mkdir -p /mnt/retired && mount "$LOOP" /mnt/retired
for i in $(seq 1 200); do echo "CONFIDENTIAL,cust$i@example.com,invoice-2026-$i,SGD
$((i*37))"; done > /mnt/retired/invoices.csv
sync; rm /mnt/retired/invoices.csv; sync; umount /mnt/retired
echo "Records still readable on the raw device after delete:"; grep -a -c 'CONFIDENTIAL'
"$LOOP"
```

```
Records still readable on the raw device after delete:
200
```

5. Clear the media with shred

`shred` overwrites the whole block device. One random pass followed by a zero pass (`-z`) meets the NIST **Clear** level for magnetic media. Afterwards, search the device again.

```
LOOP=$(cat /root/itam/loopdev)
shred -v -n 1 -z "$LOOP"
grep -a -c 'CONFIDENTIAL' "$LOOP" || echo "-> 0 matches: data no longer recoverable by
software"
```

6. Use the alternatives: dd zero-fill and blkdiscard

`dd` is the universal overwrite tool. `blkdiscard` sends TRIM/discard, which on SSDs and thin-provisioned storage tells the device to release the blocks. On a loop device it punches holes in the backing file.

```
LOOP=$(cat /root/itam/loopdev)
SIZE=$(blockdev --getsize64 "$LOOP")
dd if=/dev/zero of="$LOOP" bs=1M count=$((SIZE/1048576)) oflag=direct status=progress
blkdiscard -f "$LOOP" && echo "blkdiscard completed" || echo "discard not supported on
this device - overwrite already done"
```

7. Verify the result and keep evidence

Verification is mandatory under NIST SP 800-88. Read back every byte and compare it with zeros, then record a hash of the sanitised device as evidence.

```
LOOP=$(cat /root/itam/loopdev)
SIZE=$(blockdev --getsize64 "$LOOP")
cmp -n "$SIZE" "$LOOP" /dev/zero && echo "VERIFIED: all $SIZE bytes of $LOOP read back as
zero"
sha256sum "$LOOP" | tee /root/itam/verify-hash.txt
head -c "$SIZE" /dev/zero | sha256sum
```

Both hashes must be identical.

8. Purge by cryptographic erase

Self-encrypting drives and phones are purged by destroying the encryption key, not by overwriting. Simulate a laptop SSD encrypted with LUKS, then erase all of its key slots. The ciphertext remains on disk but can never be decrypted.

```
cd /root/itam
truncate -s 32M laptop-ssd.img
head -c 64 /dev/urandom > laptop-ssd.key && chmod 600 laptop-ssd.key
cryptsetup luksFormat --batch-mode --type luks2 laptop-ssd.img laptop-ssd.key
cryptsetup luksDump laptop-ssd.img | grep -A2 '^Keyslots:'
cryptsetup luksErase --batch-mode laptop-ssd.img
cryptsetup luksDump laptop-ssd.img | grep -A2 '^Keyslots:'
cryptsetup open --test-passphrase --key-file laptop-ssd.key laptop-ssd.img || echo
"PURGED: no key slot can unlock this volume"
```

9. Issue the certificate and close the asset record

Produce a certificate using the NIST SP 800-88 Appendix G fields, update the inventory status and detach the device.

```
cd /root/itam
LOOP=$(cat loopdev)
cat > certificate-SG-DISK-0099.txt <<EOF
CERTIFICATE OF MEDIA SANITISATION (fields per NIST SP 800-88 Rev. 1, Appendix G)
------------------------------------------------------------------------------
Asset tag / serial     : SG-DISK-0099 / SN-LAB0099
Media type / model     : Virtual block device, 64 MiB ($LOOP)
Data owner             : Finance (CFO)
Data classification    : Confidential
Retention / legal hold : Retention met, no legal hold (disposal-request-SG-DISK-0099.txt)
Sanitisation level     : Clear (NIST SP 800-88)
Technique and tools    : shred -n 1 -z, dd zero fill, blkdiscard ($(shred --version | head
-1))
Verification method    : Full read-back, cmp against /dev/zero, 0 residual matches
Verification SHA-256   : $(awk '{print $1}' verify-hash.txt)
Post-sanitisation      : Reuse internally, or send to an e-waste vendor for destruction
Performed by           : $(whoami)@$(hostname)
Date and time (UTC)    : $(date -u '+%Y-%m-%d %H:%M')
Validated by           : _____________________ (independent witness)
EOF
cat certificate-SG-DISK-0099.txt
sed -i 's/^\(SG-DISK-0099,.*\),Retired$/\1,Sanitised - certificate on file/' inventory.csv
grep '^SG-DISK-0099' inventory.csv
losetup -d "$LOOP" && echo "$LOOP detached"
```

Test it

```
cd /root/itam
grep -a -c CONFIDENTIAL retired-disk.img; echo "residual-matches-exit=$?"
```

```
grep -E 'Sanitisation level|Verification SHA-256' certificate-SG-DISK-0099.txt
grep '^SG-DISK-0099' inventory.csv | cut -d, -f9
```

Expected: `0` with `residual-matches-exit=1` (nothing found), a certificate showing the Clear level and a 64-hex-character hash, and the inventory status `Sanitised - certificate on file`.

Troubleshooting

Symptom	Fix
`losetup: cannot find an unused loop device`	Run `modprobe loop`, then repeat step 4. List devices in use with `losetup -a`.
`mount: wrong fs type` in step 4	`mkfs.ext4` did not run against `$LOOP`. Re-run `LOOP=$(cat /root/itam/loopdev)` and repeat the mkfs.
`cmp: EOF on /dev/zero` or a differing byte	The overwrite was interrupted. Re-run step 6, then step 7.

Challenge

Add an asset `SG-PH-0201` (a COPE phone) to the inventory and write a decommissioning procedure for it: remote wipe through MDM, factory reset, cryptographic erase, removal from the MDM tenant and the certificate fields you would collect from the disposal vendor.

Reflection

A failed SSD that cannot be overwritten holds Restricted payment data. Which NIST SP 800-88 level and technique do you choose, who signs the certificate, and why is overwriting alone a poor choice for SSDs?

Exam tips

- Clear = overwrite (software recovery defeated); Purge = crypto erase, secure erase or degauss (lab recovery defeated); Destroy = shred, pulverise, incinerate.
- Degaussing works only on magnetic media. It does nothing to SSDs or flash; use crypto erase or physical destruction there.
- Certification (a certificate of destruction or sanitisation) is the evidence an auditor asks for, especially when a third party does the work.
- Ownership means an accountable person is assigned; classification decides how the asset is handled. Inventory is the list you hold; enumeration is active discovery.

References

- NIST SP 800-88 Rev. 1, Guidelines for Media Sanitization — https://csrc.nist.gov/pubs/sp/800/88/r1/final
- NIST SP 1800-5, IT Asset Management — https://www.nccoe.nist.gov/publication/1800-5/
- CIS Critical Security Controls 1 and 2 (inventory of hardware and software assets) — https://www.cisecurity.org/controls
- Singapore PDPC Guide to Disposal of Personal Data on Physical Medium — https://www.pdpc.gov.sg